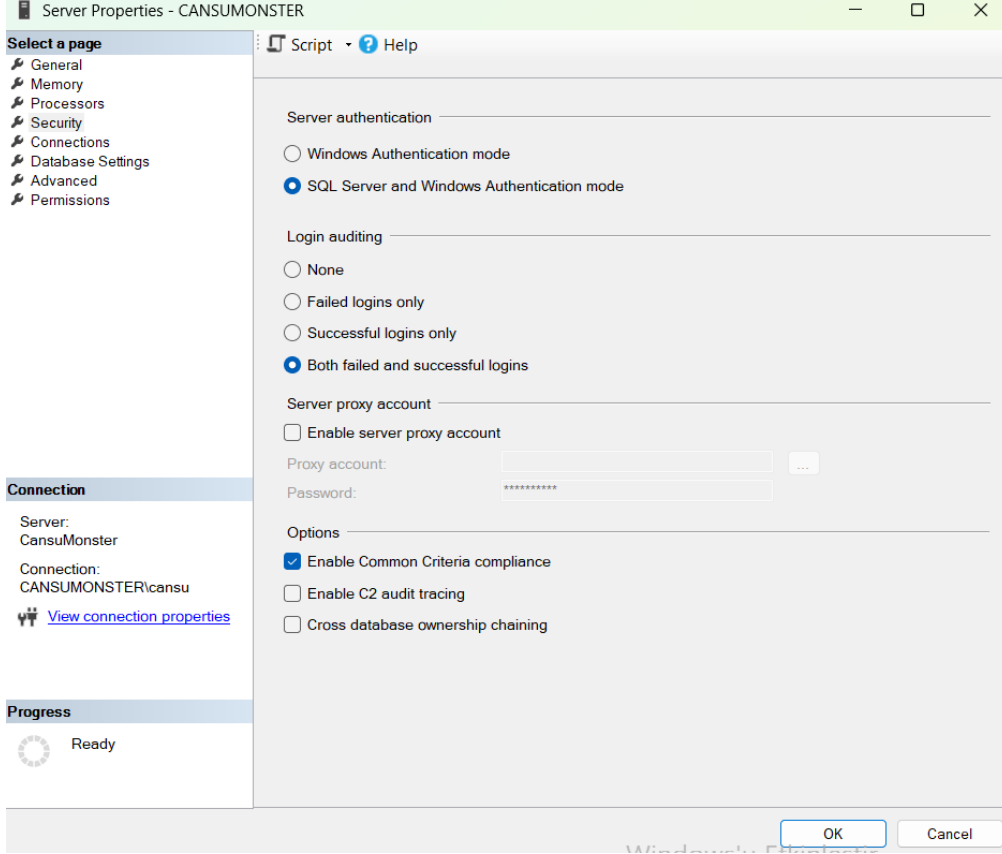


2.Proje: Veritabanı Güvenliği ve Eriřim Kontrolü

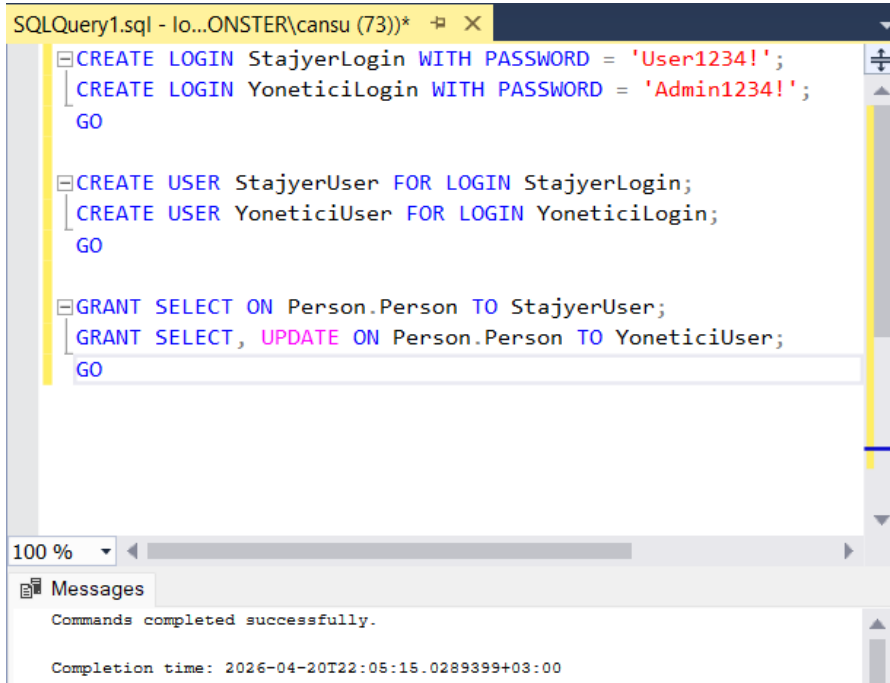
a. Eriřim Yönetimi



Server authentication olarak SQL Server ve Windows Authentication mode yani Mixed Mode seçilmiştir.

Login auditing ise “Both failed and successful logins” seçilerek hem başarılı hem de başarısız girişler kayıt altına alınır.

Options olarak ise ISO/IEC 15408 uluslararası güvenlik standardı aktif hale getirilir.



```
SQLQuery1.sql - lo...ONSTER\cansu (73))* X
CREATE LOGIN StajyerLogin WITH PASSWORD = 'User1234!';
CREATE LOGIN YoneticiLogin WITH PASSWORD = 'Admin1234!';
GO

CREATE USER StajyerUser FOR LOGIN StajyerLogin;
CREATE USER YoneticiUser FOR LOGIN YoneticiLogin;
GO

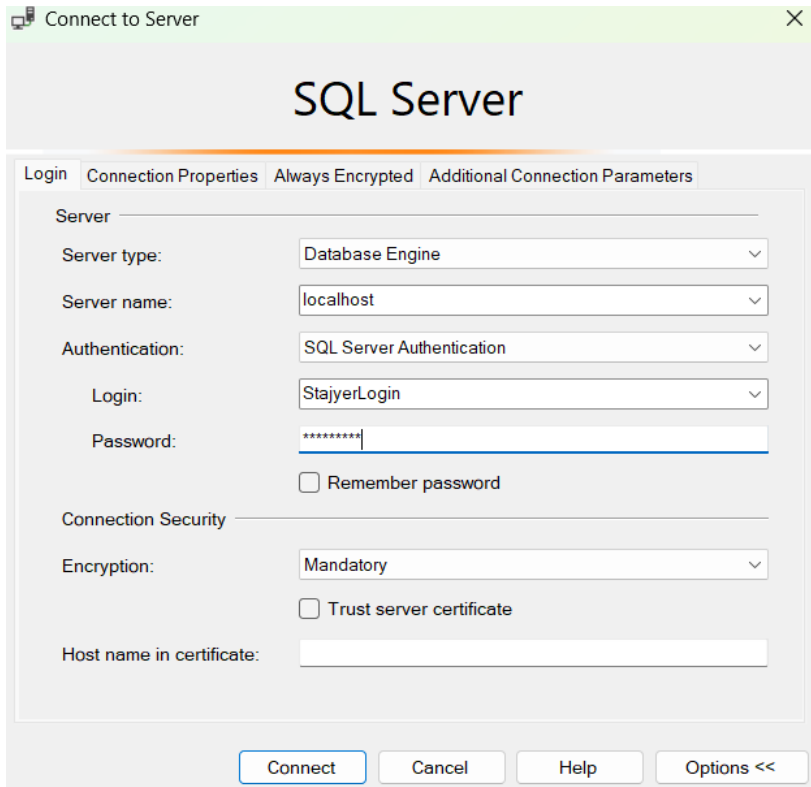
GRANT SELECT ON Person.Person TO StajyerUser;
GRANT SELECT, UPDATE ON Person.Person TO YoneticiUser;
GO

100 %
Messages
Commands completed successfully.

Completion time: 2026-04-20T22:05:15.0289399+03:00
```

StajyerLogin ve YoneticiLogin için girişler ve özel şifreler ayarlanır. Kullanıcılar, ayarlanan özel girişler ile yaratılır.

Kullanıcıların, veri tabanındaki üzerinde değişiklik yapabilecekleri tablo belirtilmiştir. Sadece YoneticiUser tablo üzerinden değişiklik yapabilir, StajyerUser ise sadece görüntüleme yapabilir.



Connect to Server

SQL Server

Login | Connection Properties | Always Encrypted | Additional Connection Parameters

Server

Server type: Database Engine

Server name: localhost

Authentication: SQL Server Authentication

Login: StajyerLogin

Password: *****

☐ Remember password

Connection Security

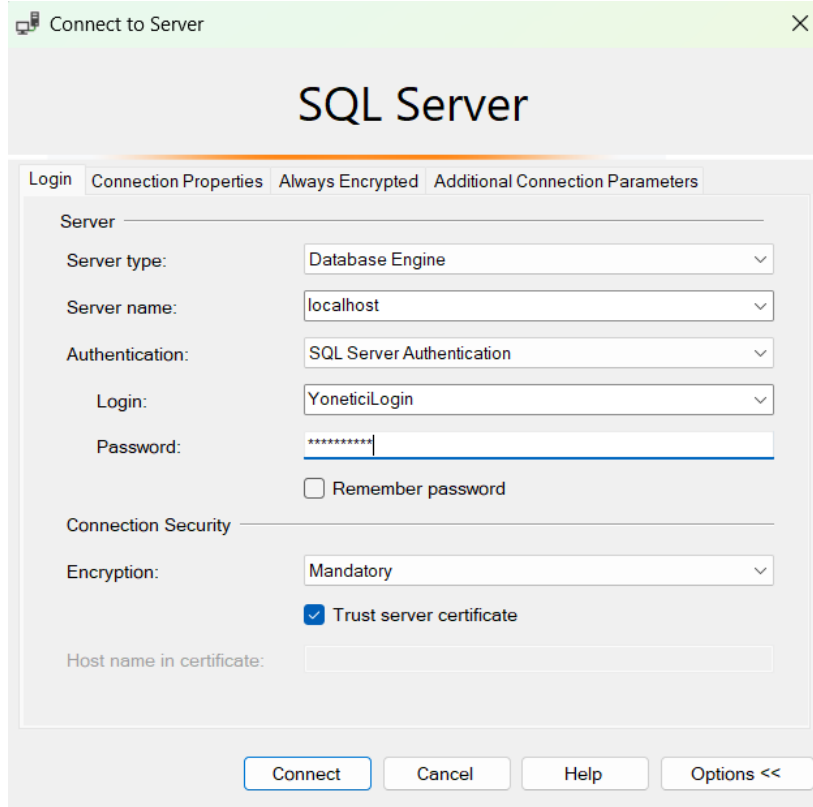
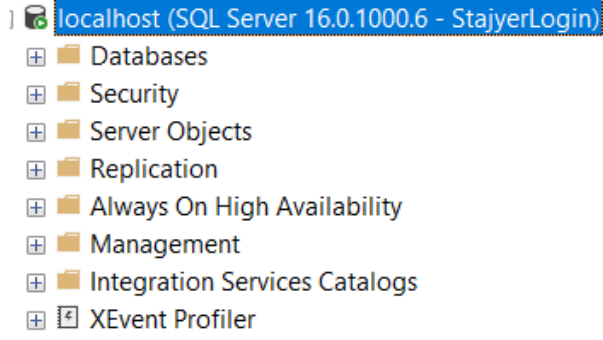
Encryption: Mandatory

☐ Trust server certificate

Host name in certificate:

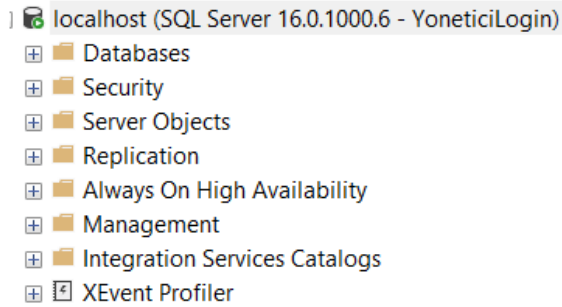
Connect Cancel Help Options <<

Yukarıdaki şekilde ayarlanan giriş ve özel şifre ile giriş yapılır. Aşağıda veri tabanına stajyer girişi yapıldığı görülmektedir.

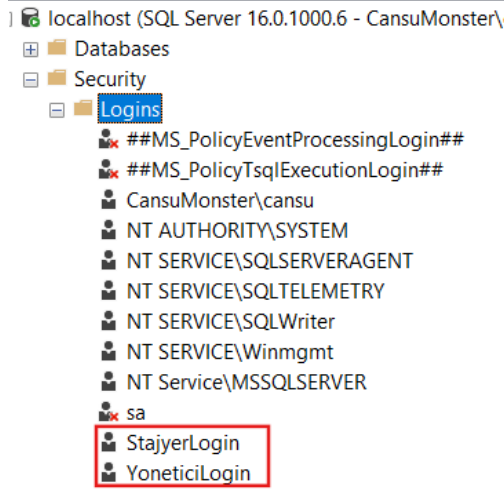


YöneticiUser için ayarlanan giriş ve özel şifre ile veri tabanına giriş yapılır.

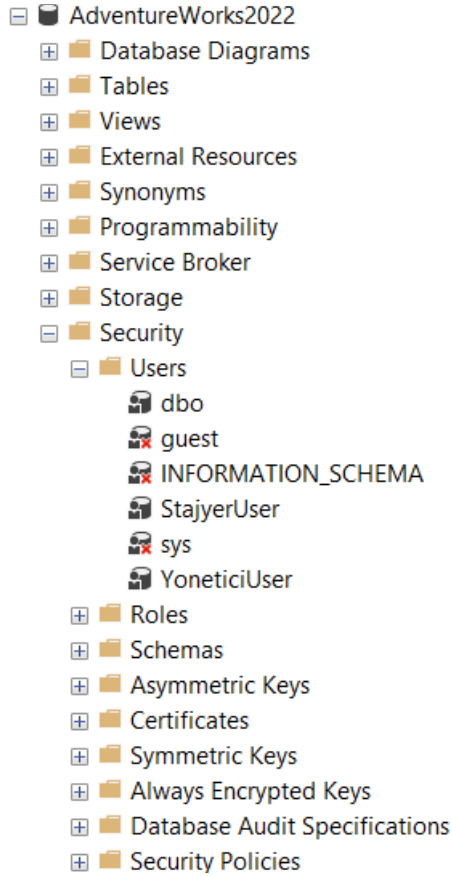
Aşağıda YoneticiLogin ile giriş sağlandığı görülmektedir.



Localhost içerisindeki Security klasöründen Logins alt klasöründen yaratılan girişler görülmektedir.



AdventureWorks2022 veri tabanına erişimi olan tüm kullanıcılar Securitiy klasörünün alt klasörü olan Users içerisinde görülmektedir.



StajyerUser tarafından Person.Person tablosunda değişiklik yapılmaya çalışılır.

```
SQLQuery4.sql - loc...(StajyerLogin (56))* X
UPDATE Person.Person SET FirstName = 'Calisan' WHERE BusinessEntityID = 1;

100 %
Messages
Msg 229, Level 14, State 5, Line 1
The UPDATE permission was denied on the object 'Person', database 'AdventureWorks2022', schema 'Person'
Completion time: 2026-04-20T23:20:53.4325926+03:00
```

Erişim Yönetimi sağlanarak StajyerUser kullanıcısının yetkisi olmadığından Person.Person tablosunda değişiklik yapılması engellenmiştir.

b. Veri Şifreleme

Sales.CreditCard tablosunda kredi kart numaralarını şifrelemek satışların ve müşterilerin güvenliği için önemlidir. Bu nedenle kredi kartı numaraları için veri şifreleme yöntemi kullanılmıştır.

```
SQLQuery5.sql - lo...ONSTER\cansu (70))* X
IF NOT EXISTS (SELECT * FROM sys.symmetric_keys WHERE name = '##MS_DatabaseMasterKey##')
BEGIN
    CREATE MASTER KEY ENCRYPTION BY PASSWORD = 'CansuŞifre123!';
END
GO

CREATE CERTIFICATE CreditCardCert
WITH SUBJECT = 'Kredi Kartı Şifreleme Sertifikası';
GO

CREATE SYMMETRIC KEY CreditCardKey
WITH ALGORITHM = AES_256
ENCRYPTION BY CERTIFICATE CreditCardCert;
GO

100 %
Messages
Commands completed successfully.
Completion time: 2026-04-20T23:46:32.6219775+03:00
```

Öncelikle bir master key anahtarı diğer anahtarları korumak için ayarlanmıştır. Daha sonra kredi kartlarına özel şifreleme sertifikası oluşturulur. AES_256 algoritması ile simetrik anahtar oluşturulur.

SQLQuery10.sql - I...ONSTER\cansu (72) X

```

SELECT TOP (1000) [CreditCardID]
, [CardType]
, [CardNumber]
, [ExpMonth]
, [ExpYear]
, [ModifiedDate]
FROM [AdventureWorks2022].[Sales].[CreditCard]

```

100 %

Results Messages

	CreditCardID	CardType	CardNumber	ExpMonth	ExpYear	ModifiedDate
1	1	SuperiorCard	33332664695310	11	2006	2013-07-29 00:00:00.000
2	2	Distinguish	55552127249722	8	2005	2013-12-05 00:00:00.000
3	3	ColonialVoice	77778344838353	7	2005	2014-01-14 00:00:00.000
4	4	ColonialVoice	77774915718248	7	2006	2013-05-20 00:00:00.000
5	5	Vista	11114404600042	4	2005	2013-02-01 00:00:00.000
6	6	Distinguish	55557132036181	9	2006	2014-04-10 00:00:00.000
7	7	Distinguish	55553635401028	6	2007	2013-02-01 00:00:00.000
8	8	SuperiorCard	33336081193101	7	2007	2013-06-30 00:00:00.000
9	9	Distinguish	55553465625901	2	2005	2013-09-23 00:00:00.000
10	10	SuperiorCard	33332126386493	8	2008	2011-08-31 00:00:00.000
11	11	SuperiorCard	33335352517363	10	2008	2014-05-04 00:00:00.000
12	12	SuperiorCard	33334316194519	4	2008	2012-05-30 00:00:00.000
13	13	Vista	11119775847802	11	2005	2014-03-01 00:00:00.000
14	14	Distinguish	55553287727410	10	2006	2013-11-19 00:00:00.000
15	15	SuperiorCard	33336866065599	11	2008	2013-01-29 00:00:00.000
16	16	Vista	11111985451507	8	2006	2013-12-30 00:00:00.000
17	17	ColonialVoice	77771220960729	8	2008	2014-01-16 00:00:00.000
18	18	ColonialVoice	77773971683137	8	2007	2011-12-29 00:00:00.000
19	19	ColonialVoice	77779803886862	9	2007	2014-02-04 00:00:00.000

localhost (16.0 RTM) | CANSUMONSTER\cansu (72) | AdventureWorks2022 | 00:00:00 | 1,000 rows

Yukarıda Sales.CreditCard tablosunun ilk hali verilmiştir.

SQLQuery11.sql - I...ONSTER\cansu (71))* X

```

ALTER TABLE Sales.CreditCard
ADD CardNumber_Encrypted VARBINARY(MAX);
GO

OPEN SYMMETRIC KEY CreditCardKey DECRYPTION BY CERTIFICATE CreditCardCert;

UPDATE Sales.CreditCard
SET CardNumber_Encrypted = ENCRYPTBYKEY(KEY_GUID('CreditCardKey'), CardNumber);

CLOSE SYMMETRIC KEY CreditCardKey;
GO

```

100 %

Messages

(19118 rows affected)

Completion time: 2026-04-21T00:07:47.1762515+03:00

Bu SQL komutları ile kredi kartı numarası ikili şekilde şifrelenir ve CardNumber_Encrypted sütunu oluşturularak bu kısma girilir.

SQLQuery12.sql - I...ONSTER\cansu (71) ✕

```
SELECT TOP (1000) [CreditCardID]
, [CardType]
, [CardNumber]
, [ExpMonth]
, [ExpYear]
, [ModifiedDate]
, [CardNumber_Encrypted]
FROM [AdventureWorks2022].[Sales].[CreditCard]
```

100 %

Results Messages

	ExpYear	ModifiedDate	CardNumber_Encrypted
1	2006	2013-07-29 00:00:00.000	0x008FF2F06A02564BA877723836B91EAF020000001703706...
2	2005	2013-12-05 00:00:00.000	0x008FF2F06A02564BA877723836B91EAF02000000DC4A566...
3	2005	2014-01-14 00:00:00.000	0x008FF2F06A02564BA877723836B91EAF02000000D7BFA4D...
4	2006	2013-05-20 00:00:00.000	0x008FF2F06A02564BA877723836B91EAF0200000044A99B5...
5	2005	2013-02-01 00:00:00.000	0x008FF2F06A02564BA877723836B91EAF02000000436851A...
6	2006	2014-04-10 00:00:00.000	0x008FF2F06A02564BA877723836B91EAF0200000077A08A5...
7	2007	2013-02-01 00:00:00.000	0x008FF2F06A02564BA877723836B91EAF020000008B770C5...
8	2007	2013-06-30 00:00:00.000	0x008FF2F06A02564BA877723836B91EAF020000003FB9FEE...
9	2005	2013-09-23 00:00:00.000	0x008FF2F06A02564BA877723836B91EAF020000003195AF4...
10	2008	2011-08-31 00:00:00.000	0x008FF2F06A02564BA877723836B91EAF0200000050CF574...
11	2008	2014-05-04 00:00:00.000	0x008FF2F06A02564BA877723836B91EAF02000000CB4CD71...
12	2008	2012-05-30 00:00:00.000	0x008FF2F06A02564BA877723836B91EAF020000006458860...
13	2005	2014-03-01 00:00:00.000	0x008FF2F06A02564BA877723836B91EAF02000000680B6D...

calhost (16.0 RTM) | CANSUMONSTER\cansu (71) | AdventureWorks2022 | 00:00:00 | 1.000 rows

SQLQuery13.sql - I...ONSTER\cansu (66)* ✕

```
OPEN SYMMETRIC KEY CreditCardKey DECRYPTION BY CERTIFICATE CreditCardKey;

SELECT *,
    CardNumber AS Orjinal,
    '*****' + RIGHT(CAST(DECRYPTBYKEY(CardNumber_Encrypted) AS VARCHAR(16)), 16) AS MaskedCardNumber
FROM Sales.CreditCard;

CLOSE SYMMETRIC KEY CreditCardKey;
```

100 %

Results Messages

	INumber_Encrypted	Orjinal	MaskedCardNumber
1	08FF2F06A02564BA877723836B91EAF020000001703706...	33332664695310	*****5310
2	08FF2F06A02564BA877723836B91EAF02000000DC4A566...	55552127249722	*****9722
3	08FF2F06A02564BA877723836B91EAF02000000D7BFA4D...	77778344838353	*****8353
4	08FF2F06A02564BA877723836B91EAF0200000044A99B5...	77774915718248	*****8248
5	08FF2F06A02564BA877723836B91EAF02000000436851A...	11114404600042	*****0042
6	08FF2F06A02564BA877723836B91EAF0200000077A08A5...	55557132036181	*****6181
7	08FF2F06A02564BA877723836B91EAF020000008B770C5...	55553635401028	*****1028
8	08FF2F06A02564BA877723836B91EAF020000003FB9FEE...	33336081193101	*****3101
9	08FF2F06A02564BA877723836B91EAF020000003195AF4...	5555346525901	*****5901
10	08FF2F06A02564BA877723836B91EAF0200000050CF574...	33332126386493	*****6493
11	08FF2F06A02564BA877723836B91EAF02000000CB4CD71...	33335352517363	*****7363
12	08FF2F06A02564BA877723836B91EAF020000006458860...	33334316194519	*****4519
13	08FF2F06A02564BA877723836B91EAF02000000680B6D...	11119775847802	*****7802
14	08FF2F06A02564BA877723836B91EAF0200000014A125E...	55553287727410	*****7410
15	08FF2F06A02564BA877723836B91EAF020000009A0C01D...	33336866065599	*****5599
16	08FF2F06A02564BA877723836B91EAF020000005FC6AEA...	11111985451507	*****1507
17	08FF2F06A02564BA877723836B91EAF02000000E4800D9...	77771220960729	*****0729
18	08FF2F06A02564BA877723836B91EAF020000008239B51...	77773971683137	*****3137
19	08FF2F06A02564BA877723836B91EAF020000001D38D37...	77779803886862	*****6862

alhost (16.0 RTM) | CANSUMONSTER\cansu (66) | AdventureWorks2022 | 00:00:00 | 19.118 rows

Bu şekilde bütün kredi kart numaraları sadece son 4 hanesi görülecek şekilde değiştirilebilir.

c. SQL Injections Senaryoları ve Stored Procedure

Bir arama yapılırken gerçekleştirilen sorguya saldırgan UNION ekleyerek farklı tablolarda saklanan bilgileri elde edebilir.

The screenshot shows a SQL query window with the following text:

```
SELECT Name, ProductNumber FROM Production.Product WHERE Name=''  
UNION  
SELECT CardNumber, CardType FROM Sales.CreditCard--'
```

Below the query window, the 'Results' tab is active, displaying a table with 20 rows. The table has two columns: 'Name' and 'ProductNumber'. The data is as follows:

	Name	ProductNumber
7	55553635401028	Distinguish
8	33336081193101	SuperiorCard
9	55553465625901	Distinguish
10	33332126386493	SuperiorCard
11	33335352517363	SuperiorCard
12	33334316194519	SuperiorCard
13	11119775847802	Vista
14	55553287727410	Distinguish
15	33336866065599	SuperiorCard
16	11111985451507	Vista
17	77771220960729	ColonialVoice
18	77773971683137	ColonialVoice
19	77779803886862	ColonialVoice
20	33332150058339	SuperiorCard

At the bottom of the window, the status bar shows: 'calhost (16.0 RTM) | CANSUMONSTER\cansu (54) | AdventureWorks2022 | 00:00:00 | 19.118 rows'.

Bu saldırılara karşı önlem olarak Stored Procedure işlemi gerçekleştirilir.


```
SQLQuery7.sql - lo...ONSTER\cansu (54))* X
CREATE PROCEDURE sp_GuvenliArama
    @UrunAdi NVARCHAR(50)
AS
BEGIN
    SELECT Name, ProductNumber
    FROM Production.Product
    WHERE Name = @UrunAdi;
END;
```

100 %

Messages

Commands completed successfully.

Completion time: 2026-04-21T02:03:40.8096212+03:00

Yeni bir kullanıcı, ona ait giriş ve özel şifre oluşturulur.

```
SQLQuery9.sql - lo...ONSTER\cansu (54))* X
CREATE LOGIN WebAppLogin WITH Password = 'SafePassword123!';
GO
```

100 %

Messages

Commands completed successfully.

Completion time: 2026-04-21T02:11:54.2934777+03:00

Bu kullanıcının Production tablosuna SELECT ile erişim izni var ama Sales.CreditCard tablosuna erişim engellenir.

```
SQLQuery10.sql - I...ONSTER\cansu (54))* X
CREATE USER WebAppUser FOR LOGIN WebAppLogin;
GO

GRANT SELECT ON SCHEMA::Production TO WebAppUser;
DENY SELECT ON SCHEMA::Sales TO WebAppUser;
GO
```

100 %

Messages

Commands completed successfully.

Completion time: 2026-04-21T02:14:47.7900401+03:00

Bu önlemlerin çalıştığını kontrol etmek için saldırganın arama girişi tekrar yapılır. Sonucunda istenildiği üzere SELECT işlemine erişim engellenir.

```
SQLQuery12.sql - I...(WebAppLogin (64))* X
SELECT Name, ProductNumber FROM Production.Product WHERE Name = ' '
UNION
SELECT CardNumber, CardType FROM Sales.CreditCard--'
```

100 %

Messages

Msg 229, Level 14, State 5, Line 1
The SELECT permission was denied on the object 'CreditCard', database 'AdventureWorks2008', server 'ONSTER'.

Completion time: 2026-04-21T02:19:17.7538522+03:00

d. SQL Server Audit

Veri tabanında yapılan silme işlemini ve işlem detaylarını log olarak tutmayı sağlar.

```
SQLQuery13.sql - I...ONSTER\cansu (64))* X
CREATE SERVER AUDIT AW_Deletion_Audit
TO FILE ( FILEPATH = 'C:\SQLAudit\' );
ALTER SERVER AUDIT AW_Deletion_Audit WITH (STATE = ON);
```

100 %

Messages

Commands completed successfully.

Completion time: 2026-04-21T08:08:47.0000594+03:00

SQL Audit klasörü açıldıktan sonra bir AW_Deletion_Audit şeklinde Sales tablosu üzerindeki silme işlemlerini kaydedecek bir Audit dosyası açılmıştır.

```
SQLQuery14.sql - I...ONSTER\cansu (64))* X
CREATE DATABASE AUDIT SPECIFICATION Audit_Delete_Sales
FOR SERVER AUDIT AW_Deletion_Audit
ADD (DELETE ON SCHEMA::Sales BY public)
WITH (STATE = ON);

100 %
Messages
Commands completed successfully.

Completion time: 2026-04-21T08:11:24.7842137+03:00
```

Ardından Sales.SalesOrderDetail üzerinden orderId = 43659 olan kayıtları silme işlemi gerçekleştirilir.

```
SQLQuery18.sql - I...ONSTER\cansu (62))* X
DELETE FROM Sales.SalesOrderDetail
WHERE SalesOrderID = 43659;

100 %
Messages
(12 rows affected)

Completion time: 2026-04-21T08:17:21.3850953+03:00
```

Aşağıda SQLAudit dosyası içerisinde DELETE işlem kaydı aranır ve bu işleme ait detaylar aşağıda verilmiştir.

```
SQLQuery21.sql - I...ONSTER\cansu (66))* X
SELECT
    event_time AS [Tarih/Saat],
    session_server_principal_name AS [Kullanıcı],
    object_name AS [Hangi Tablo],
    statement AS [Çalıştırılan Sorgu],
    server_instance_name AS [Sunucu]
FROM sys.fn_get_audit_file ('C:\SQLAudit\*', DEFAULT, DEFAULT)
WHERE statement LIKE '%DELETE%'
ORDER BY event_time DESC;

100 %
Results Messages
Tarih/Saat      Kullanıcı      Hangi Tablo      Çalıştırılan Sorgu
1 2026-04-21 05:17:20.6851812 MicrosoftAccount\cansuyurukoglu07@gmail.com SalesOrderDetail DELETE FROM Sales.SalesOrderDetail
```

